Ethical Hacking and Penetration Testing (VA)

Penetration Testing

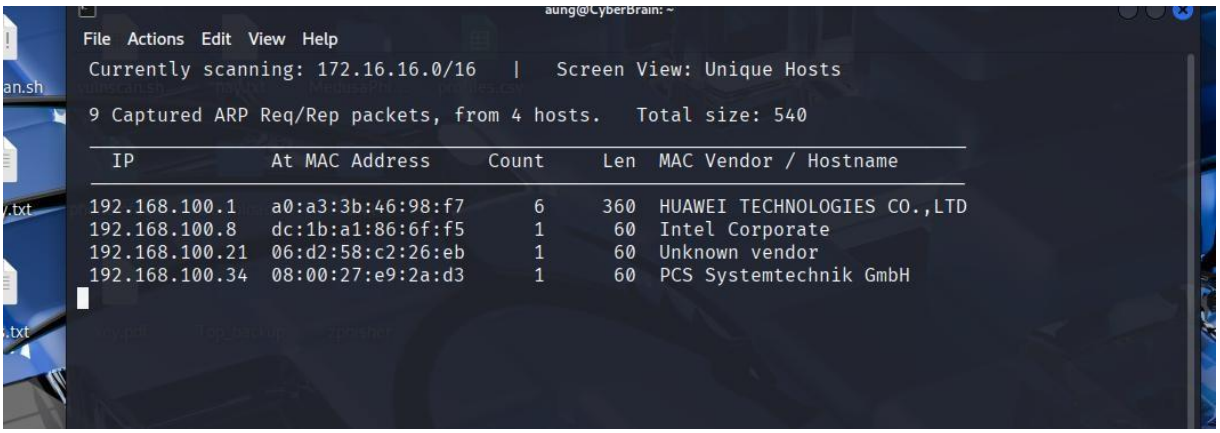
1. Introduction & Objectives

- **Overview:** In this practical lab, I focused on leveraging the Nmap Scripting Engine (NSE) to enhance traditional reconnaissance and perform comprehensive vulnerability assessments.
- **Lab Environment:** The testing was conducted using **Kali Linux** as the primary attack platform against a vulnerable target machine (**Metasploitable**).

2. Step-by-Step Execution

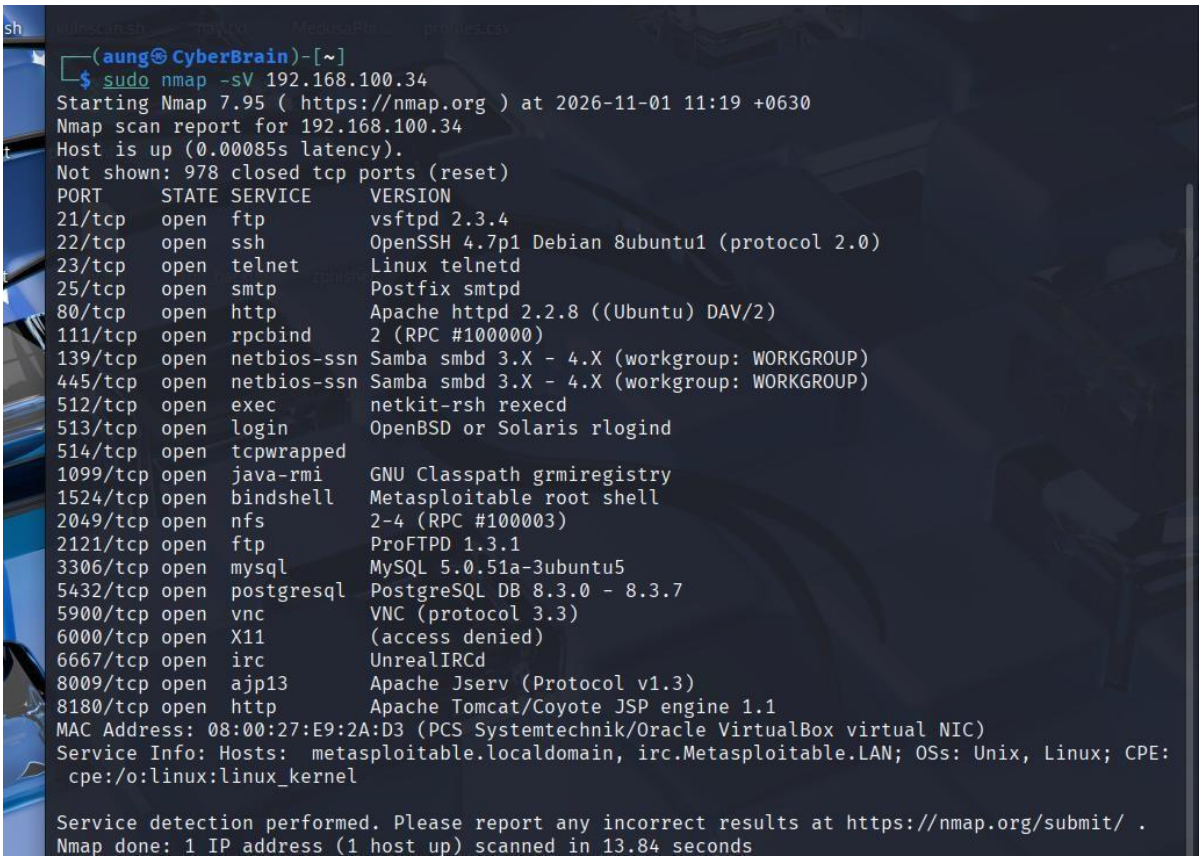
Step 1: Discovering the Target IP

- **Tool Used:** `netdiscover`
- **How it was done:** Before running any attacks, I used the `netdiscover` utility to scan the local network segment. By listening to ARP traffic, the tool successfully uncovered active hosts and revealed the precise IP address of the target machine (`192.168.100.34`)



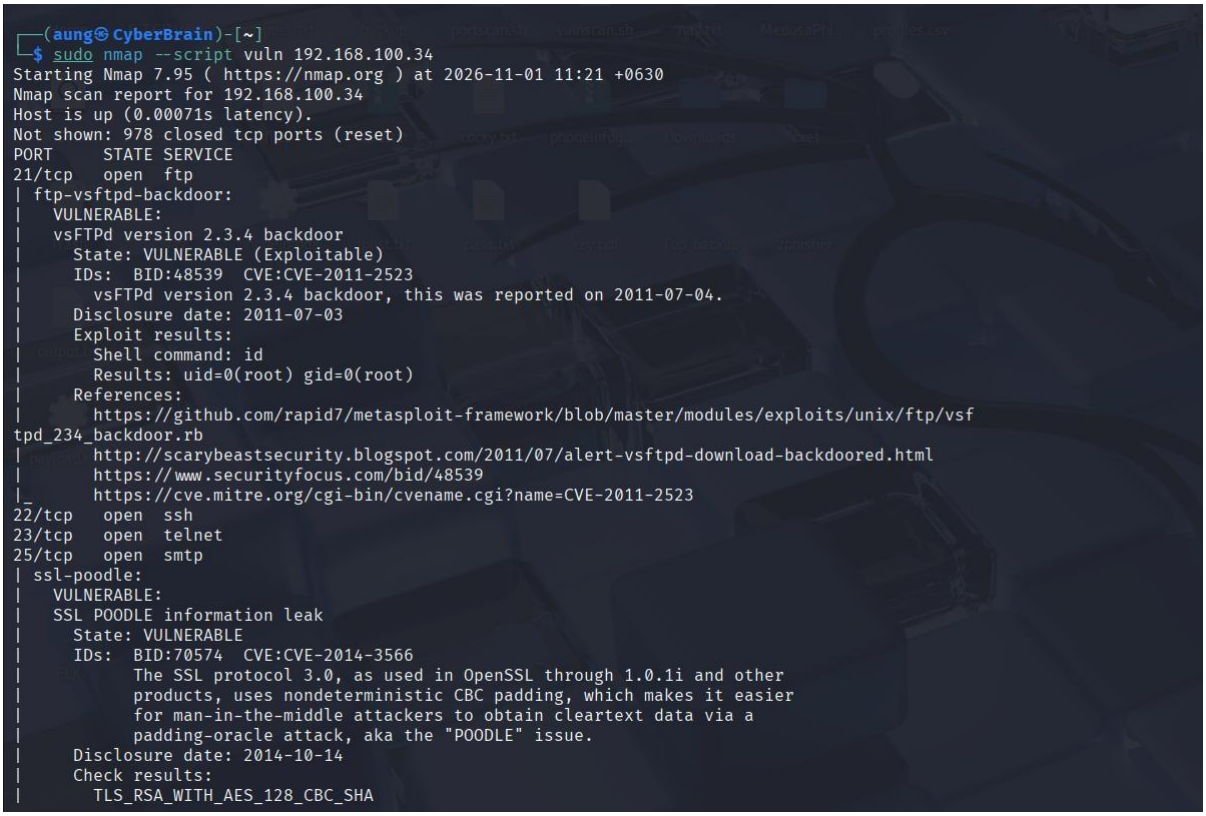
Step 2: Enumeration and Version Detection

- **Tool Used:** `nmap` (with version detection flags)
- **How it was done:** Once the target IP was confirmed, I executed Nmap port scanning combined with service version detection (`-sV`) to identify which ports and services were currently active and listening on the target.



Step 3: Vulnerability Scanning via NSE

- **Tool Used:** Nmap Scripting Engine (`--script vuln`)
- **How it was done:** To find security flaws, I applied specific NSE vulnerability scripts. This allowed me to automatically check for known vulnerabilities, misconfigurations, and potential exploit vectors associated with the target's running services.



2. Footprinting & Reconnaissance

- **Individual Assignment:** Apply website mirroring tools & competitive intelligence tools.

Lab Testing & Methodology

- **Objective:** To gather target information, analyze competitive intelligence, and mirror a target website for offline examination using Kali Linux.

Step 1: Competitive Intelligence & Information Gathering

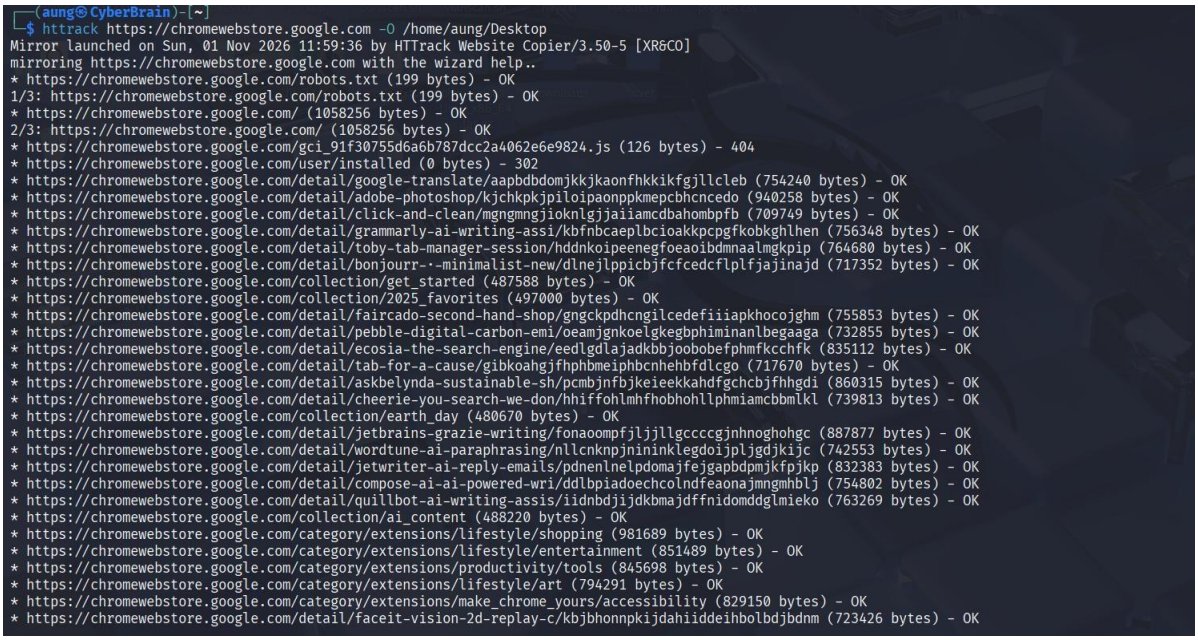
- **Tool Used:** `theHarvester`
- **How it was done:**
    - Before conducting active testing, I used `theHarvester` to perform open-source intelligence (OSINT) gathering on the target domain. This tool helps collect emails, subdomains, and open-source data associated with the target organization.



Verification: Successfully retrieved public-facing subdomains and associated email addresses.

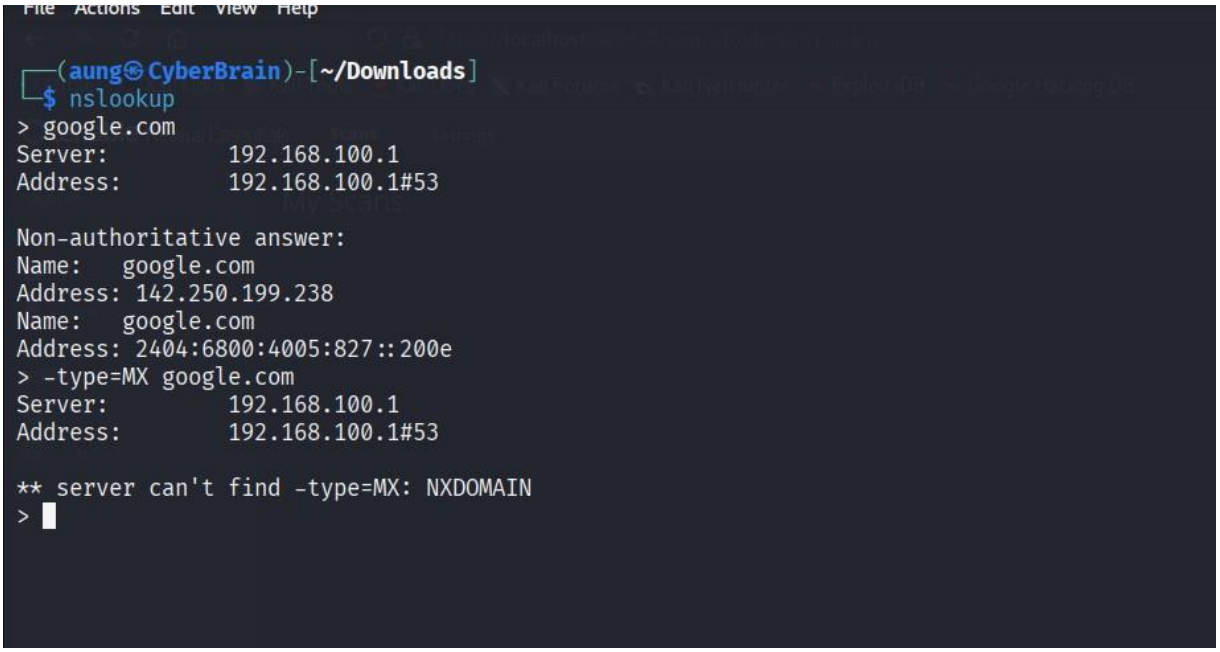
Step 2: Website Mirroring for Offline Analysis

- **Tool Used:** `HTTrack Website Copier`
- **How it was done:**
    - To analyze the structure and contents of a target website offline, I utilized HTTrack to mirror the site. This downloads the HTML, images, and other directories from the live server to a local directory.

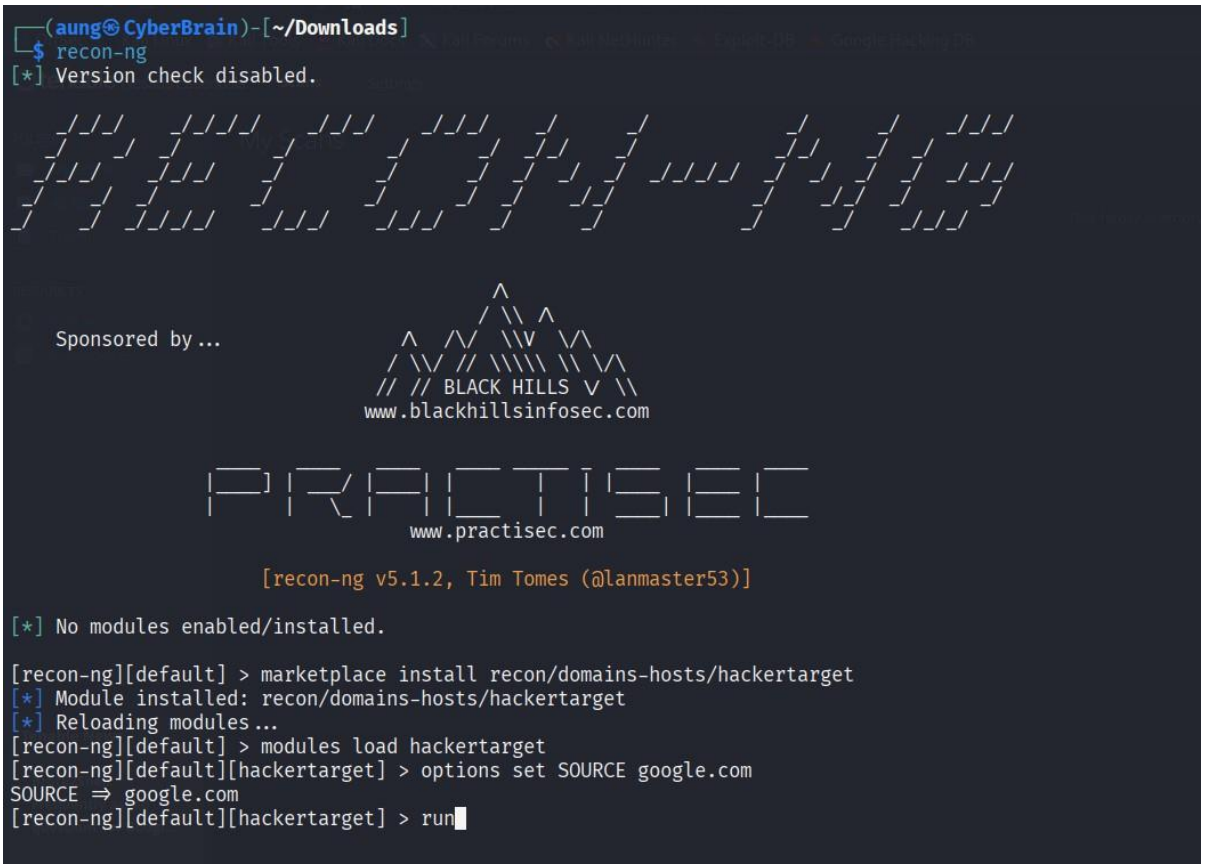


Verification: The website files and directory structures were successfully downloaded locally for code review and vulnerability analysis.

Use nslookup



Recon-ng


(aung㉿CyberBrain)-[~/Downloads]
$ recon-ng
[*] Version check disabled.
Sponsored by...
BLACK HILLS
www.blackhillsinfosec.com
www.practisec.com
[recon-ng v5.1.2, Tim Tomes (@lanmaster53)]
[*] No modules enabled/installed.
[recon-ng][default] > marketplace install recon/domains-hosts/hackertarget
[*] Module installed: recon/domains-hosts/hackertarget
[*] Reloading modules...
[recon-ng][default] > modules load hackertarget
[recon-ng][default][hackertarget] > options set SOURCE google.com
SOURCE ⇒ google.com
[recon-ng][default][hackertarget] > run

```
SOURCE ⇒ google.com
[recon-ng][default][hackertarget] > run

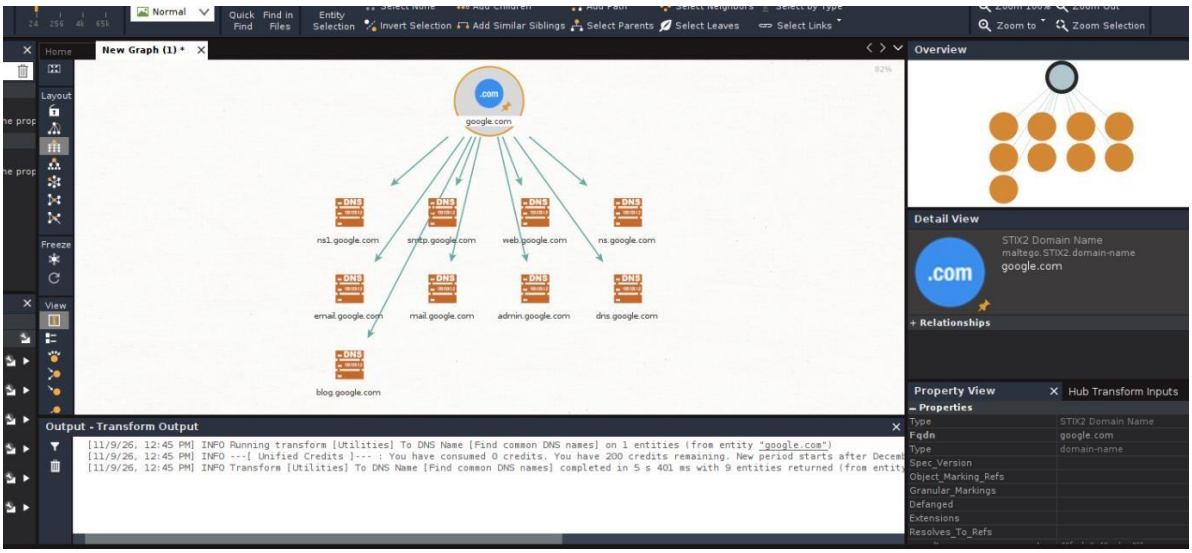
_________
GOOGLE.COM
_________
[*] Country: None
[*] Host: 1.google.com
[*] Ip_Address: 142.250.68.206
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] ------------------------------------------------------
[*] Country: None
[*] Host: 216-239-33-25.google.com
[*] Ip_Address: 216.239.33.25
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] ------------------------------------------------------
[*] Country: None
[*] Host: 216-239-45-10.google.com
[*] Ip_Address: 216.239.45.10
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] ------------------------------------------------------
[*] Country: None
[*] Host: 216-239-45-32.google.com
[*] Ip_Address: 216.239.45.32
[*] Latitude: None
[*] Longitude: None
```

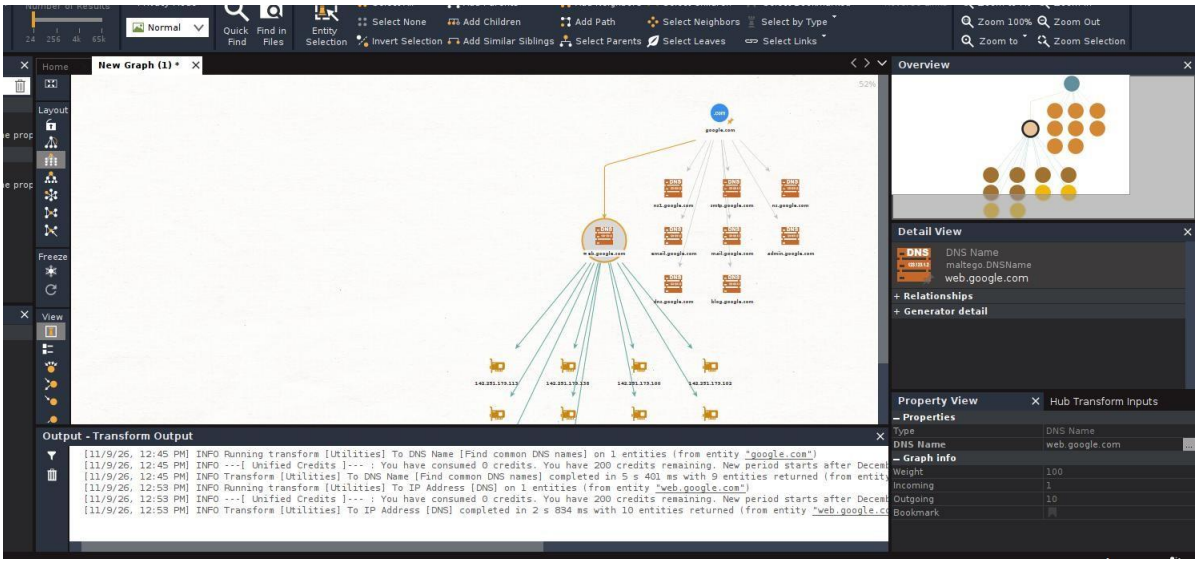
```
[*] Country: None
[*] Host: borgmon.evenflow.adz.google.com
[*] Ip_Address: 64.233.180.129
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] ---------------------------------------------------
[*] Country: None
[*] Host: frame.ads-devel.qa.adz.google.com
[*] Ip_Address: 64.233.178.129
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] ---------------------------------------------------
[*] Country: None
[*] Host: ads-external-devel.qa.adz.google.com
[*] Ip_Address: 64.233.178.129
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] ---------------------------------------------------
[*] Country: None
[*] Host: ads-external-prod.qa.adz.google.com
[*] Ip_Address: 64.233.178.129
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] ---------------------------------------------------

SUMMARY

[*] 50 total (50 new) hosts found.
[recon-ng][default][hackertarget] >
```

Use Maltago





3. Scanning Networks

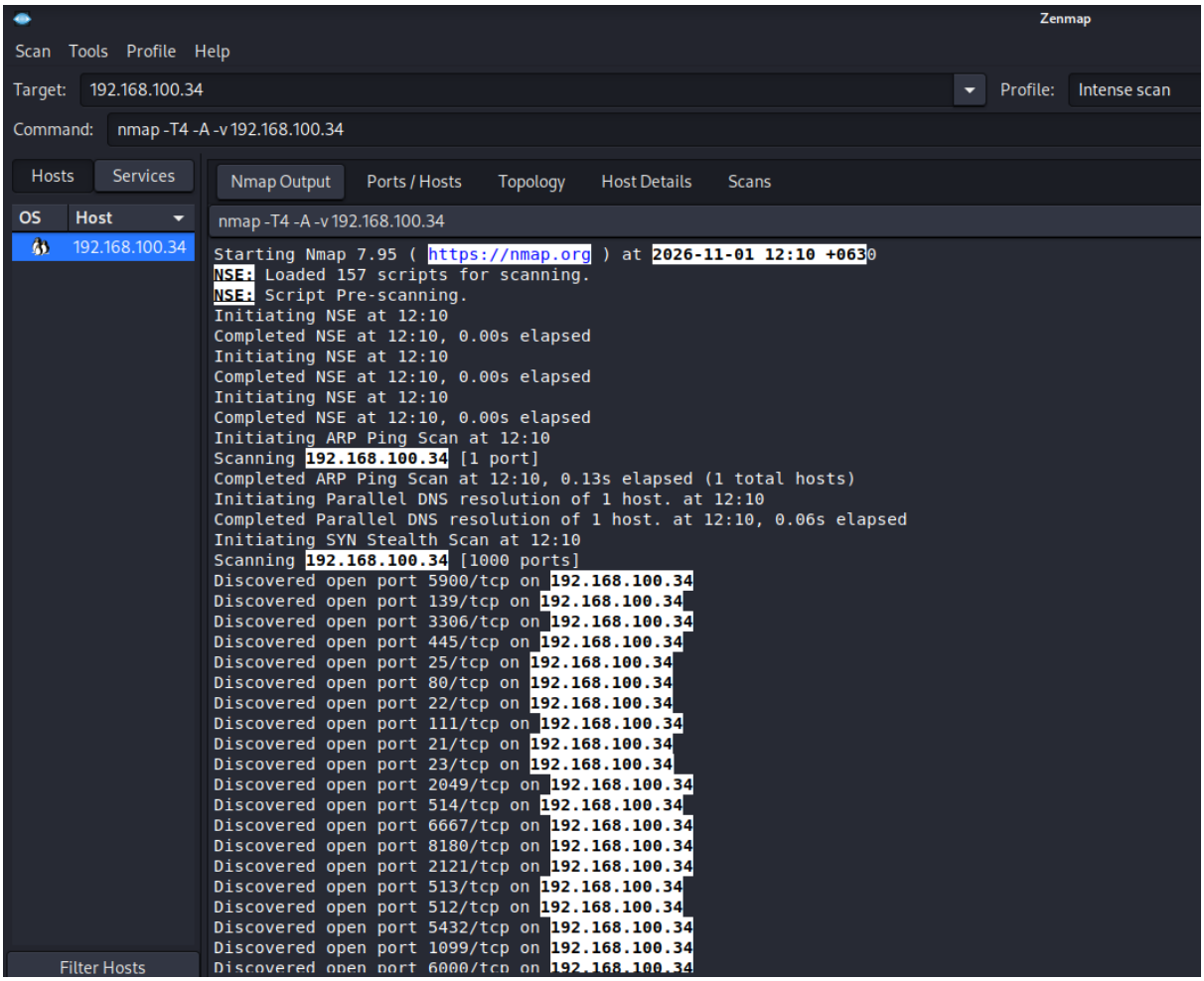
- **Individual Assignment:** Create a network topology map based on the scan using Zenmap.

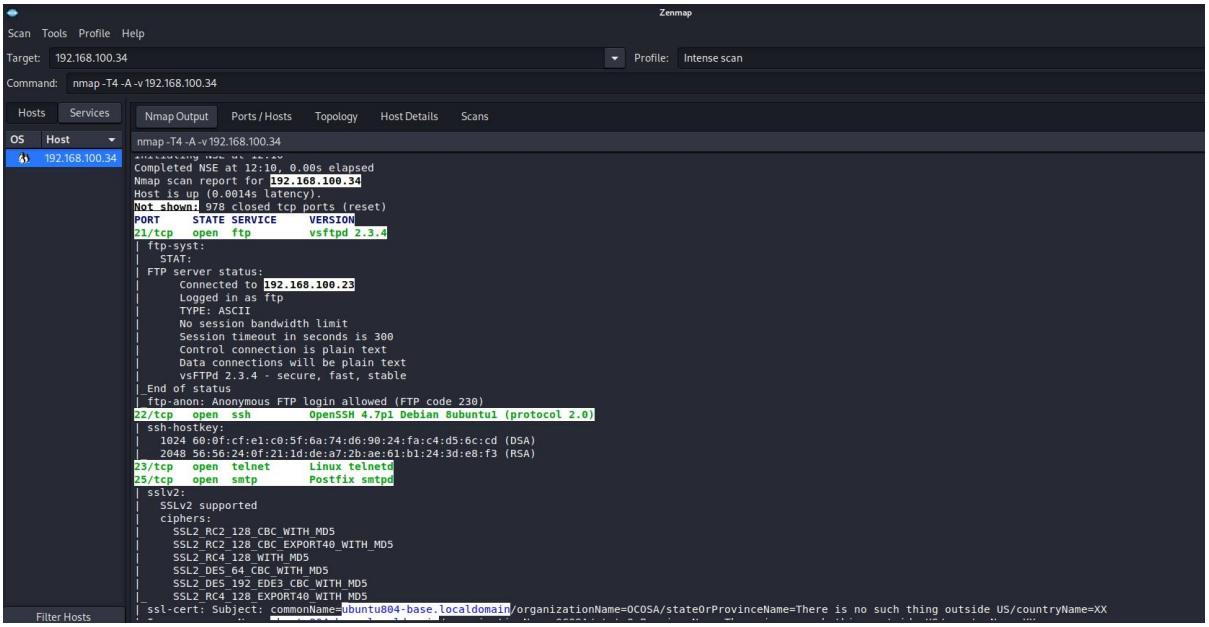
Lab Testing & Methodology

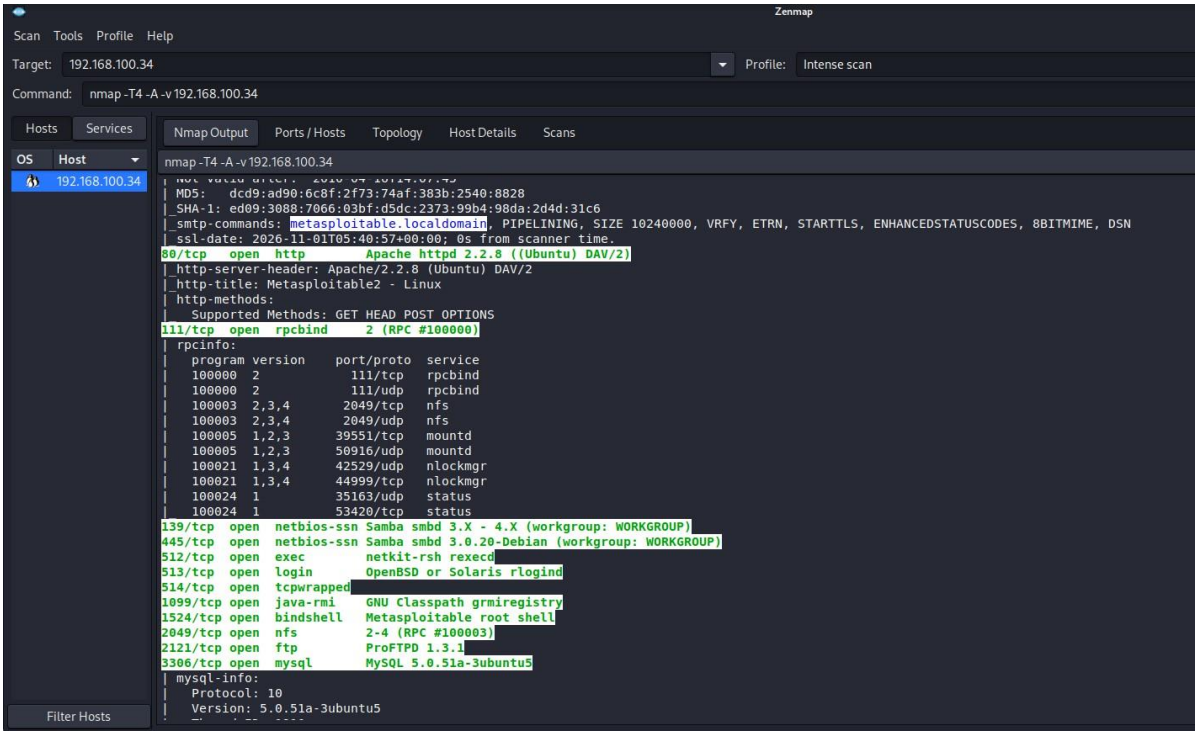
- **Objective:** To discover active network hosts, analyze connection structures, and generate a visual network topology map using Zenmap (Nmap GUI) in Kali Linux.

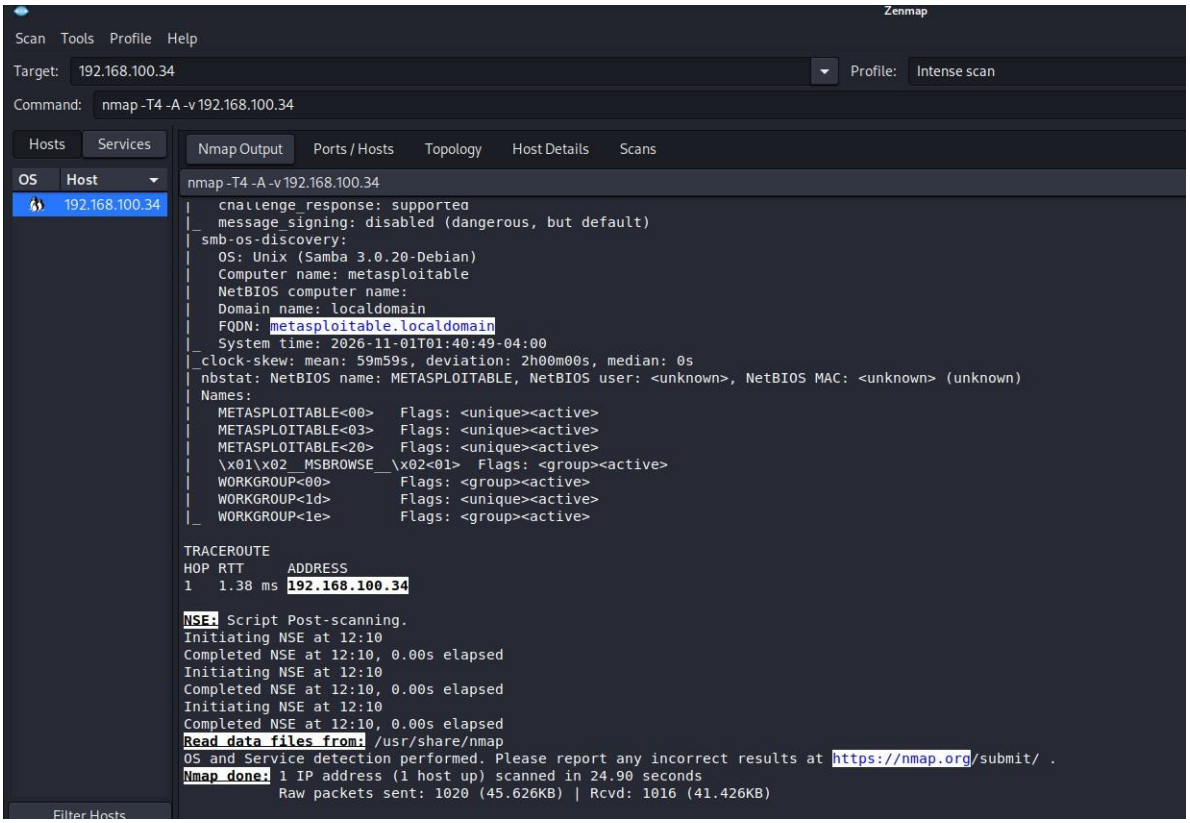
Step 1: Launching Zenmap & Setting Target

- **Tool Used:** `Zenmap` (Graphical User Interface for Nmap)
- **How it was done:**
    - I launched Zenmap and entered the local lab network range (`192.168.100.34`) into the **Target** field to scan all active devices within the segment.


Zenmap
Scan Tools Profile Help
Target: 192.168.100.34
Profile: Intense scan
Command: nmap -T4 -A -v 192.168.100.34
Hosts Services
OS Host
192.168.100.34
Filter Hosts
Nmap Output Ports / Hosts Topology Host Details Scans
nmap -T4 -A -v 192.168.100.34
Starting Nmap 7.95 (https://nmap.org) at 2026-11-01 12:10 +0630
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 12:10
Completed NSE at 12:10, 0.00s elapsed
Initiating NSE at 12:10
Completed NSE at 12:10, 0.00s elapsed
Initiating NSE at 12:10
Completed NSE at 12:10, 0.00s elapsed
Initiating ARP Ping Scan at 12:10
Scanning 192.168.100.34 [1 port]
Completed ARP Ping Scan at 12:10, 0.13s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 12:10
Completed Parallel DNS resolution of 1 host. at 12:10, 0.06s elapsed
Initiating SYN Stealth Scan at 12:10
Scanning 192.168.100.34 [1000 ports]
Discovered open port 5900/tcp on 192.168.100.34
Discovered open port 139/tcp on 192.168.100.34
Discovered open port 3306/tcp on 192.168.100.34
Discovered open port 445/tcp on 192.168.100.34
Discovered open port 25/tcp on 192.168.100.34
Discovered open port 80/tcp on 192.168.100.34
Discovered open port 22/tcp on 192.168.100.34
Discovered open port 111/tcp on 192.168.100.34
Discovered open port 21/tcp on 192.168.100.34
Discovered open port 23/tcp on 192.168.100.34
Discovered open port 2049/tcp on 192.168.100.34
Discovered open port 514/tcp on 192.168.100.34
Discovered open port 6667/tcp on 192.168.100.34
Discovered open port 8180/tcp on 192.168.100.34
Discovered open port 2121/tcp on 192.168.100.34
Discovered open port 513/tcp on 192.168.100.34
Discovered open port 512/tcp on 192.168.100.34
Discovered open port 5432/tcp on 192.168.100.34
Discovered open port 1099/tcp on 192.168.100.34
Discovered open port 6000/tcp on 192.168.100.34

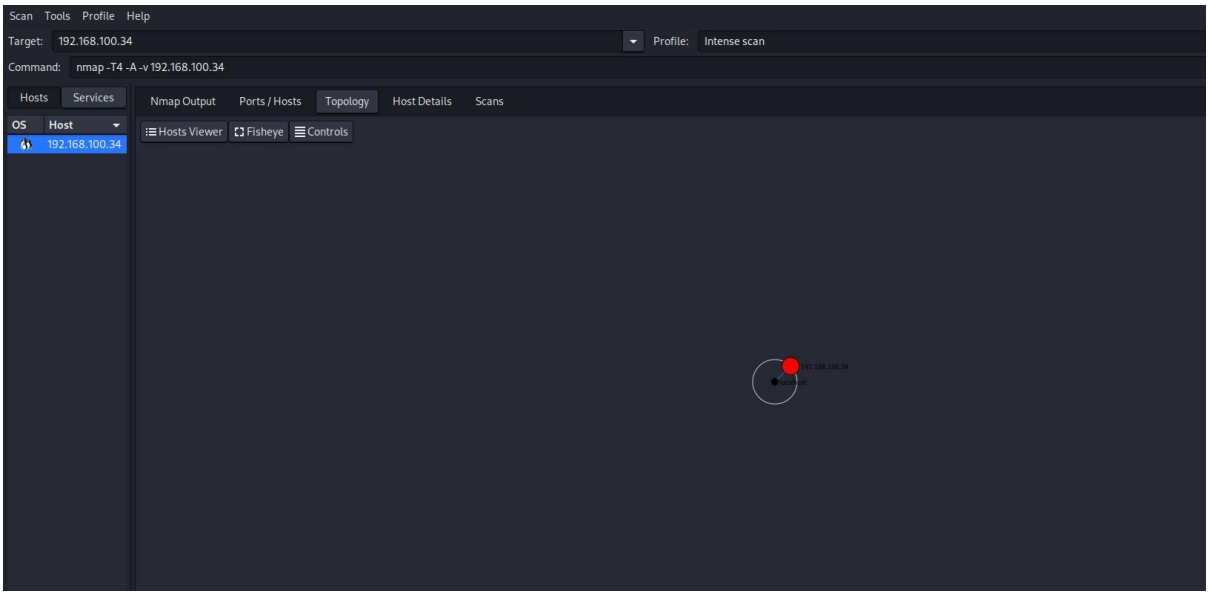

Zenmap
Scan Tools Profile Help
Target: 192.168.100.34
Profile: Intense scan
Command: nmap -T4 -A -v 192.168.100.34
Hosts Services
OS Host
192.168.100.34
Filter Hosts
Nmap Output Ports / Hosts Topology Host Details Scans
nmap -T4 -A -v 192.168.100.34
Completed NSE at 12:10, 0.00s elapsed
Nmap scan report for 192.168.100.34
Host is up (0.0014s latency).
Not shown: 978 closed tcp ports (reset)
PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 2.3.4
| ftp-syst:
| STAT:
| FTP server status:
| Connected to 192.168.100.23
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| vsFTPd 2.3.4 - secure, fast, stable
| End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
| 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp open telnet Linux telnetd
25/tcp open smtp Postfix smtpd
| sslv2:
| SSLv2 supported
| ciphers:
| SSL2_RC2_128_CBC_WITH_MD5
| SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
| SSL2_RC4_128_WITH_MD5
| SSL2_DES_64_CBC_WITH_MD5
| SSL2_DES_192_EDE3_CBC_WITH_MD5
| SSL2_RC4_128_EXPORT40_WITH_MD5
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX


Zenmap
Scan Tools Profile Help
Target: 192.168.100.34
Profile: Intense scan
Command: nmap -T4 -A -v 192.168.100.34
Hosts Services
OS Host
192.168.100.34
Filter Hosts
Nmap Output Ports / Hosts Topology Host Details Scans
nmap -T4 -A -v 192.168.100.34
| MD5: dcd9:ad90:6c8f:2f73:74af:383b:2540:8828
|_SHA-1: ed09:3088:7066:03bf:d5dc:2373:99b4:98da:2d4d:31c6
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-11-01T05:40:57+00:00; 0s from scanner time.
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
111/tcp open rpcbind 2 (RPC #100000)
| rpcinfo:
| program version port/proto service
| 100000 2 111/tcp rpcbind
| 100000 2 111/udp rpcbind
| 100003 2,3,4 2049/tcp nfs
| 100003 2,3,4 2049/udp nfs
| 100005 1,2,3 39551/tcp mountd
| 100005 1,2,3 50916/udp mountd
| 100021 1,3,4 42529/udp nlockmgr
| 100021 1,3,4 44999/tcp nlockmgr
| 100024 1 35163/udp status
|_ 100024 1 53420/tcp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login OpenBSD or Solaris rlogind
514/tcp open tcpwrapped
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5


Zenmap
Scan Tools Profile Help
Target: 192.168.100.34
Profile: Intense scan
Command: nmap -T4 -A -v 192.168.100.34
Hosts Services
OS Host
192.168.100.34
Filter Hosts
Nmap Output Ports / Hosts Topology Host Details Scans
nmap -T4 -A -v 192.168.100.34
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
| smb-os-discovery:
| OS: Unix (Samba 3.0.20-Debian)
| Computer name: metasploitable
| NetBIOS computer name:
| Domain name: localdomain
| FQDN: metasploitable.localdomain
|_ System time: 2026-11-01T01:40:49-04:00
|_clock-skew: mean: 59m59s, deviation: 2h00m00s, median: 0s
| nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| Names:
| METASPLOITABLE<00> Flags: <unique><active>
| METASPLOITABLE<03> Flags: <unique><active>
| METASPLOITABLE<20> Flags: <unique><active>
| \x01\x02__MSBROWSE__\x02<01> Flags: <group><active>
| WORKGROUP<00> Flags: <group><active>
| WORKGROUP<1d> Flags: <unique><active>
|_ WORKGROUP<1e> Flags: <group><active>
TRACEROUTE
HOP RTT ADDRESS
1 1.38 ms 192.168.100.34
NSE: Script Post-scanning.
Initiating NSE at 12:10
Completed NSE at 12:10, 0.00s elapsed
Initiating NSE at 12:10
Completed NSE at 12:10, 0.00s elapsed
Initiating NSE at 12:10
Completed NSE at 12:10, 0.00s elapsed
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.90 seconds
Raw packets sent: 1020 (45.626KB) | Rcvd: 1016 (41.426KB)

Step 2: Generating Network Topology Map

- **Tool Used:** Zenmap Topology Tab
- **How it was done:**
    - Once the scan completed successfully, I navigated to the **Topology** tab within Zenmap's results interface. This automatically mapped out the relationship and connection paths between the host machine and the target network nodes.



Verification: Successfully generated and visualized the network topology map showing connected nodes.

4. Vulnerability Analysis

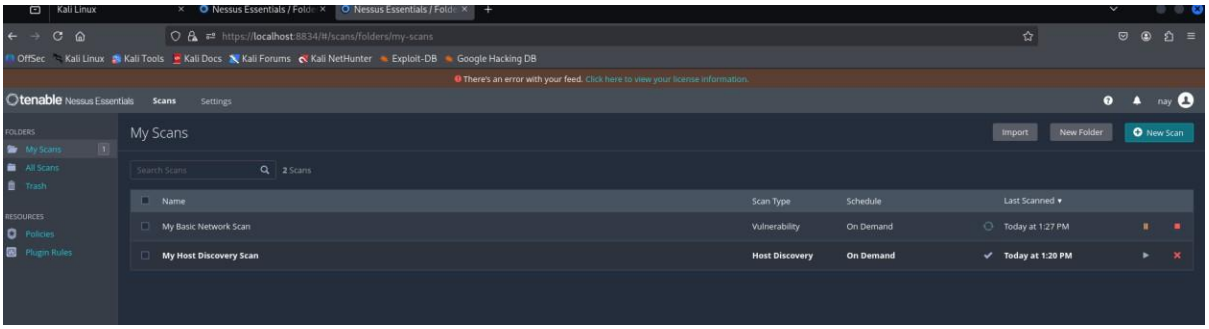
- **Individual Assignment:** Apply a vulnerability analyzer using Nessus vulnerability analysis tool.

Lab Testing & Methodology

- **Objective:** To perform a comprehensive vulnerability scan on the target system using Nessus in order to detect security flaws, misconfigurations, and outdated services.

Step 1: Accessing Nessus Web Console

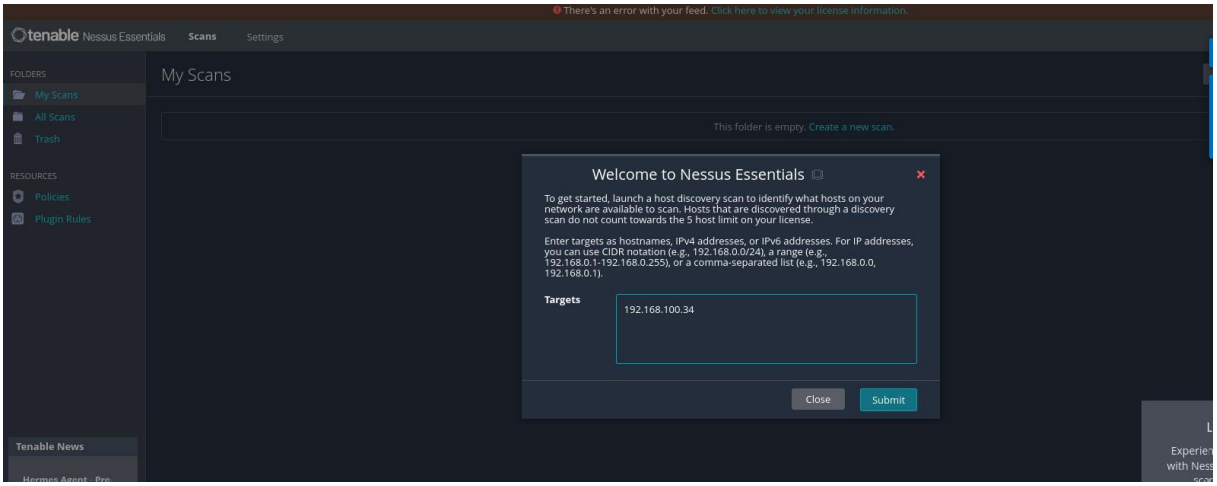
- **Tool Used:** Nessus Vulnerability Scanner
- **How it was done:**
    - I started the Nessus service on Kali Linux and opened the web interface via browser (`https://localhost:8834`) using my credentials.

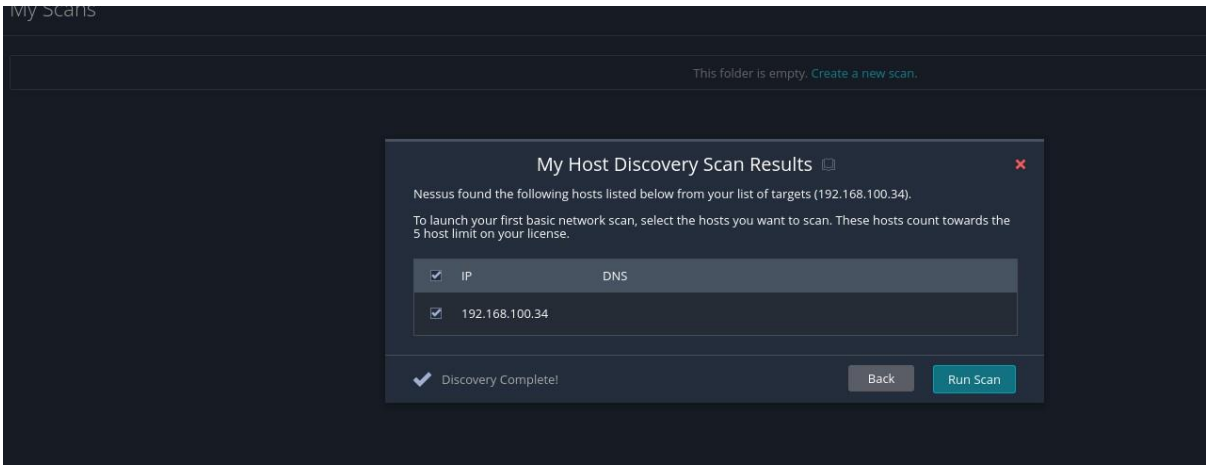


- **Verification:** Successfully accessed the Nessus web console and logged into the dashboard interface.

Step 2: Configuring and Launching the Scan

- **Tool Used:** Nessus Basic Network Scan Template
- **How it was done:**
    - Created a new scan task, entered the target machine's IP address (`192.168.100.34`), and launched a vulnerability scan to inspect open ports and potential security gaps.

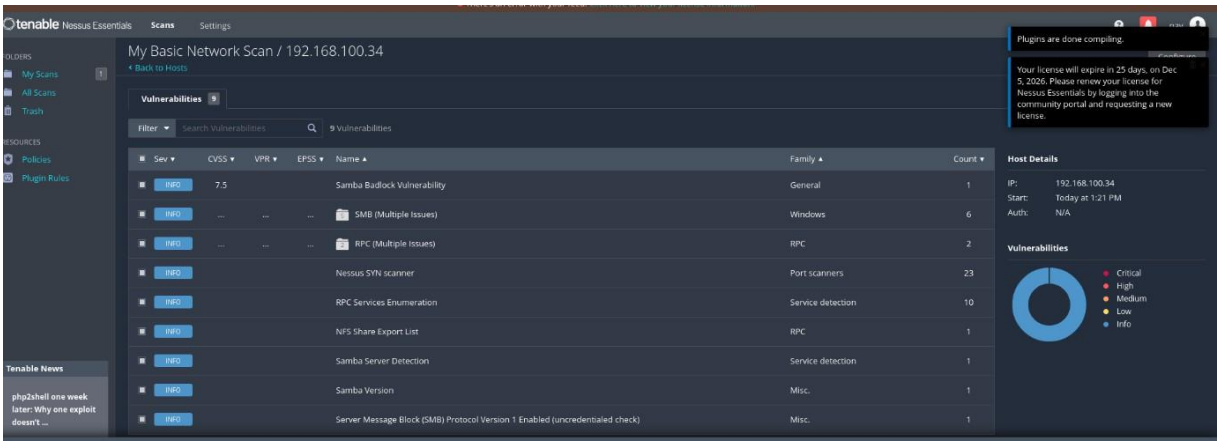




- **Verification:** Successfully initiated and executed the basic network scan against the target host.

Step 3: Reviewing Vulnerability Report

- **Tool Used:** Nessus Results Dashboard
- **How it was done:**
    - Analyzed the generated scan report, which categorized vulnerabilities and security issues (such as SMB and Samba vulnerabilities) to identify exploitable weaknesses on the target.



- **Verification:** Successfully identified vulnerabilities and security misconfigurations on the target host.

5. Social Engineering

- **Individual Assignment:** Explain human-based social engineering and computer-based social engineering.

Lab Testing & Methodology

- **Objective:** To demonstrate and analyze human-based and computer-based social engineering techniques using social engineering frameworks in Kali Linux.

Step 1: Human-Based Social Engineering Analysis

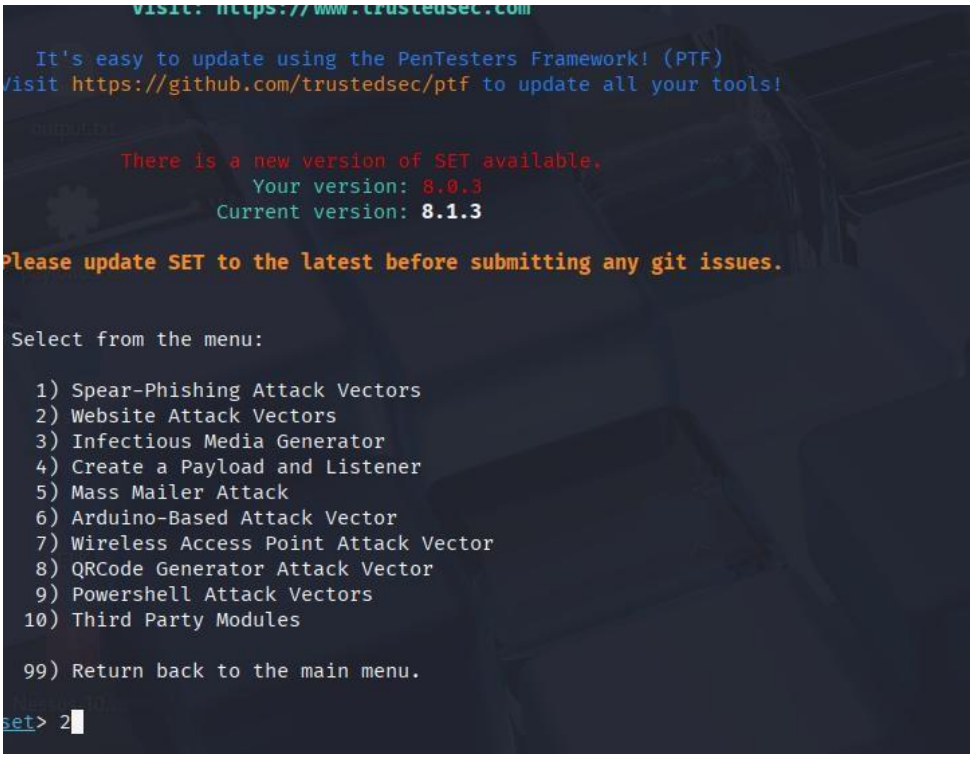
- **Tool Used:** `Social-Engineer Toolkit (SET)`
- **How it was done:**
    - I launched `setoolkit` in Kali Linux and navigated to the social engineering attack module to review human-based attack vectors, including pretexting and impersonation scenarios, to understand how psychological manipulation is used against targets.

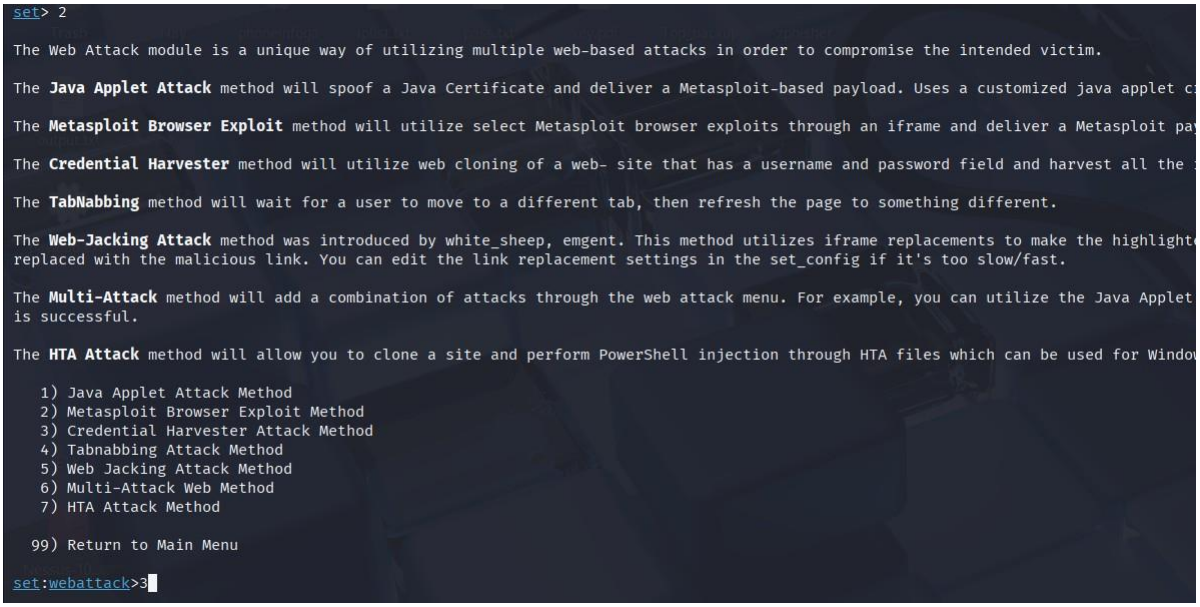


- **Verification:** Successfully identified key human-based vectors used to manipulate personnel into revealing confidential information.

Step 2: Computer-Based Social Engineering (Phishing Simulation)

- **Tool Used:** `Social-Engineer Toolkit (SET) - Credential Harvester`
- **How it was done:**
    - I utilized `setoolkit` to perform a credential harvester attack simulation by configuring the site cloner module to create a replica login page hosted on the local machine to analyze credential harvesting techniques.


Visit: https://www.trustedsec.com
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!
There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3
Please update SET to the latest before submitting any git issues.
Select from the menu:
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.
set> 2


set> 2
The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.
The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet
The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit
The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the
The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.
The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlight
replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.
The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet
is successful.
The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windo
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu
set:webattack>3

```
set:webattack>2
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

-------------------------------------------------------------------------
--- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ---

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.100.23]: 192.168.100.23
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: www.gmail.com

[*] Cloning the website: https://accounts.google.com
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

```
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.100.23]: 192.168.100.23
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: www.gmail.com

[*] Cloning the website: https://accounts.google.com
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.100.23 - - [04/Nov/2026 09:58:58] "GET / HTTP/1.1" 200 -
192.168.100.23 - - [04/Nov/2026 09:59:00] "GET /favicon.ico HTTP/1.1" 404 -
192.168.100.23 - - [04/Nov/2026 10:01:23] "GET / HTTP/1.1" 200 -
192.168.100.8 - - [04/Nov/2026 10:03:11] "GET / HTTP/1.1" 200 -
192.168.100.8 - - [04/Nov/2026 10:03:11] "GET /favicon.ico HTTP/1.1" 404 -
192.168.100.23 - - [04/Nov/2026 10:04:28] "GET / HTTP/1.1" 200 -
192.168.100.23 - - [04/Nov/2026 10:04:29] "GET /favicon.ico HTTP/1.1" 404 -
192.168.100.21 - - [04/Nov/2026 10:08:09] "GET / HTTP/1.1" 200 -
192.168.100.21 - - [04/Nov/2026 10:08:10] "GET /favicon.ico HTTP/1.1" 404 -
```

6. Hacking Web Application

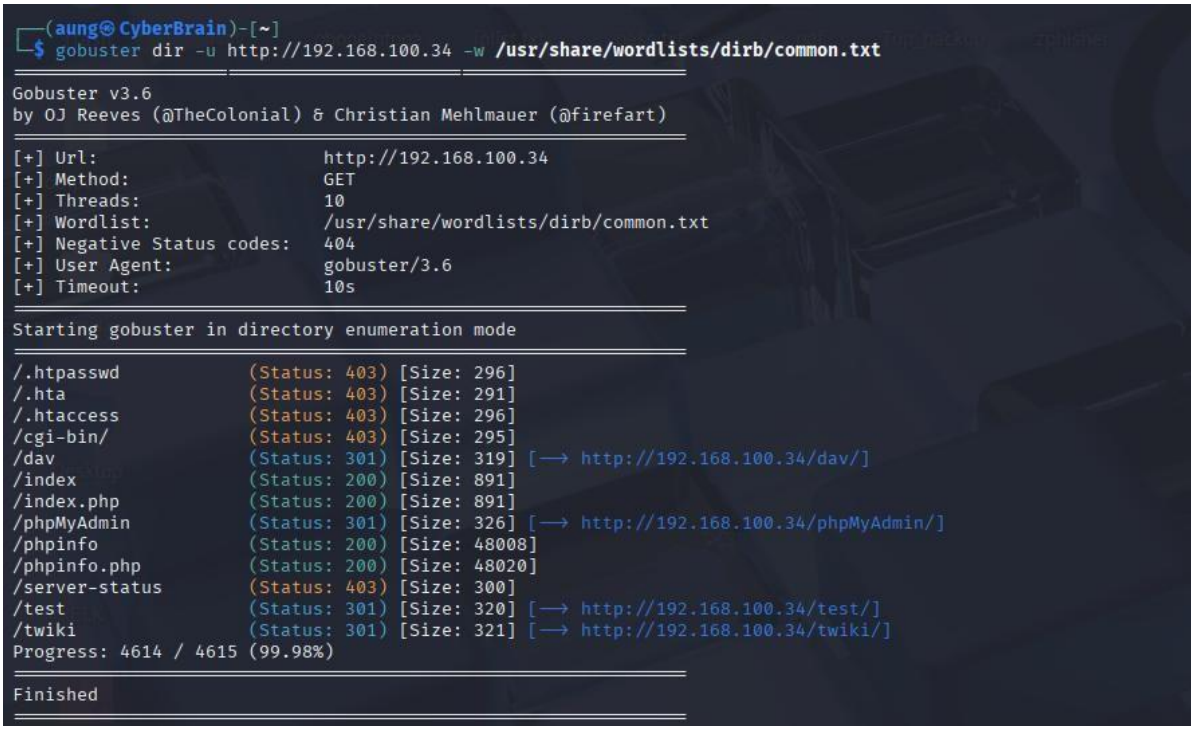
- **Individual Assignment:** Explain file inclusion attack & cross-site scripting attack.

Lab Testing & Methodology

- **Objective:** To explain, analyze, and demonstrate the concepts, mechanisms, and prevention techniques of File Inclusion (LFI/RFI) and Cross-Site Scripting (XSS) attacks in web applications.

Step 1: Explaining File Inclusion Attacks (LFI/RFI)

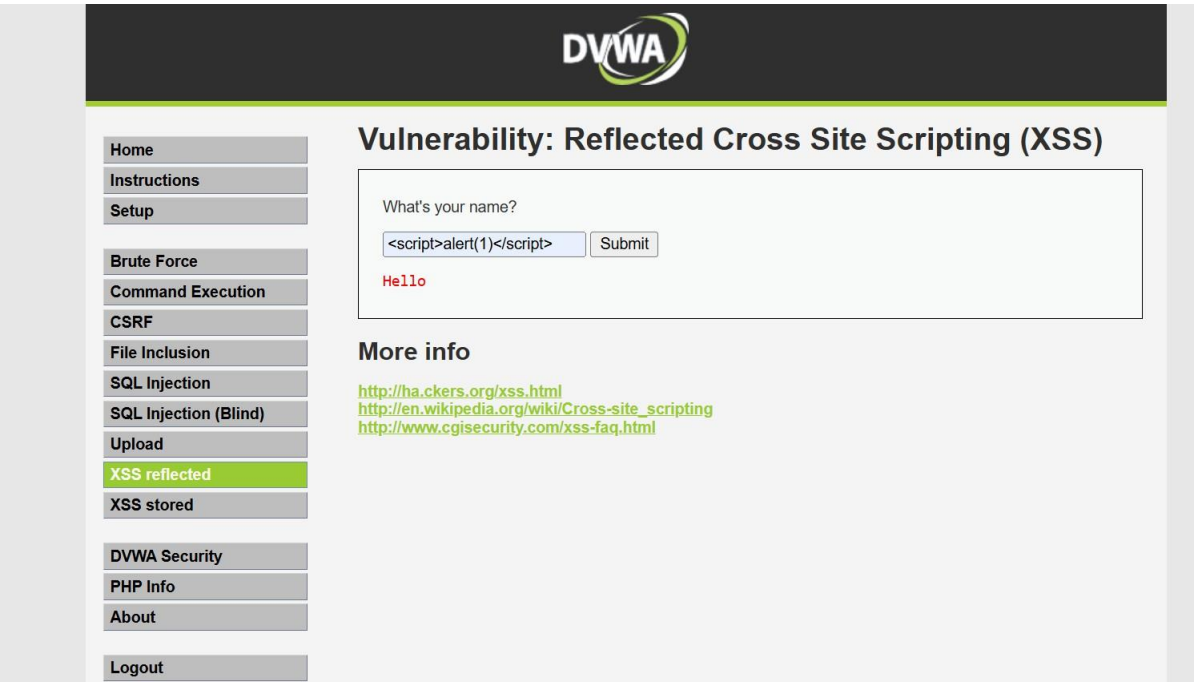
- **Tool Used:** `gobuster`
- **How it was done:**
    - To discover hidden directories, files, and potential application paths on the target web server, I utilized `gobuster` in directory mode (`dir`) combined with a standard wordlist. This helps identify hidden endpoints and structures that could be vulnerable to file inclusion or unauthorized access.

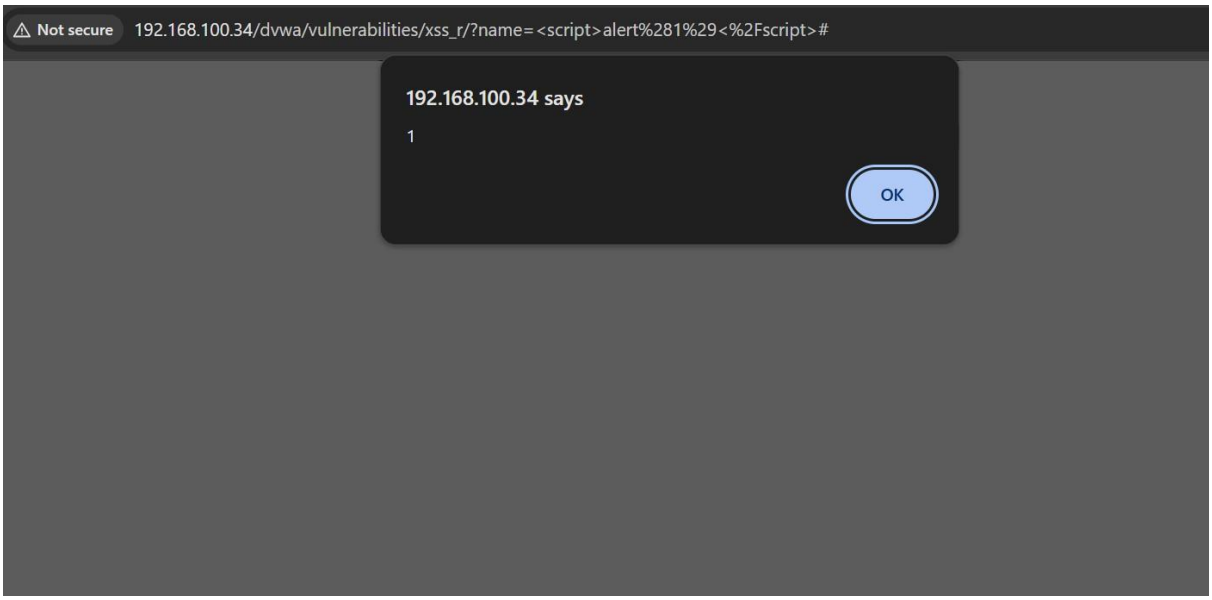


Verification: Successfully enumerated web directories and uncovered hidden file paths on the target server.

Step 2: Explaining Cross-Site Scripting (XSS) Attacks

- **Tool Used:** Web Browser & XSS Payload (`<script>alert(1)</script>`)
- **How it was done:**
    - Tested user-supplied input fields by injecting a test script payload (`<script>alert(1)</script>`) to check whether the web application properly sanitizes and encodes user input before reflecting it back to the browser.





- Verified if the application executes the injected script, which indicates a Cross-Site Scripting (XSS) vulnerability.

7.Cryptography Concepts

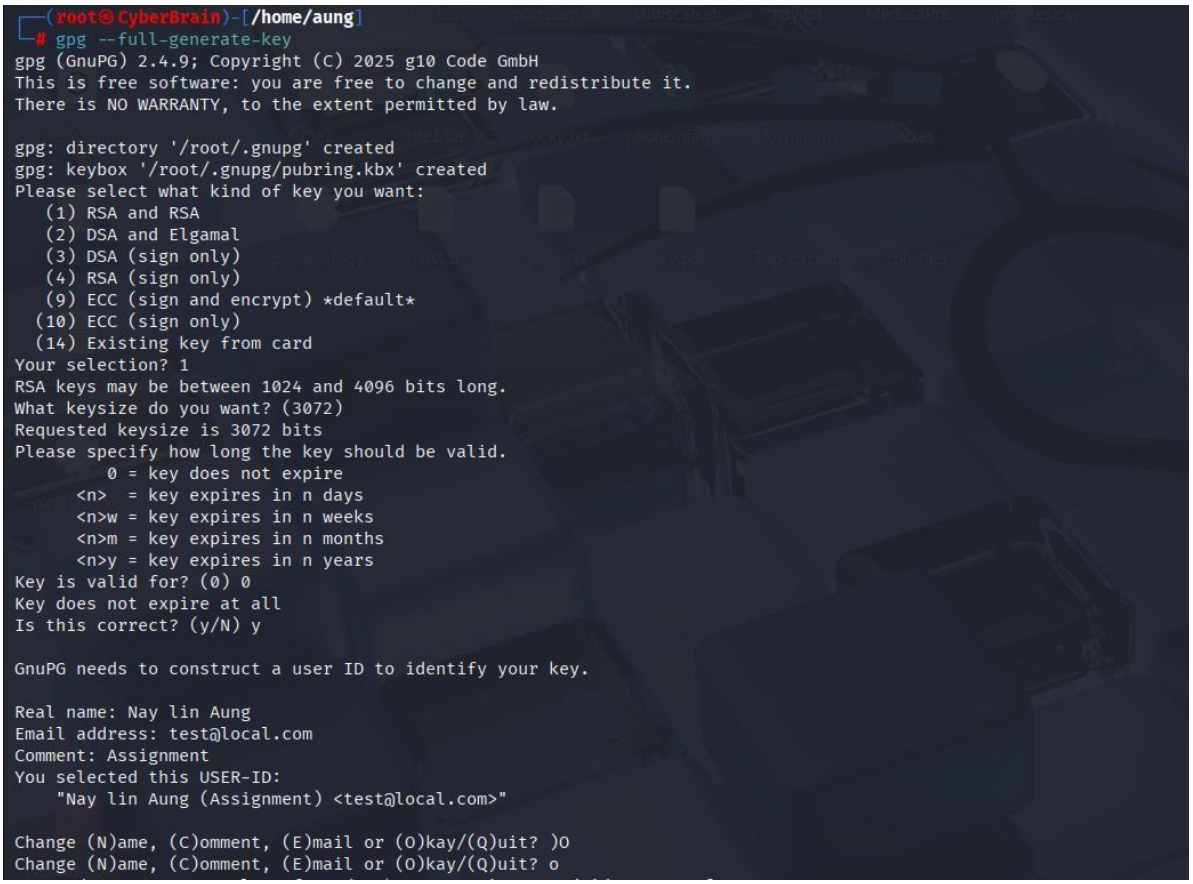
- **Individual Assignment:** Perform a disk-based encryption and an email encryption.

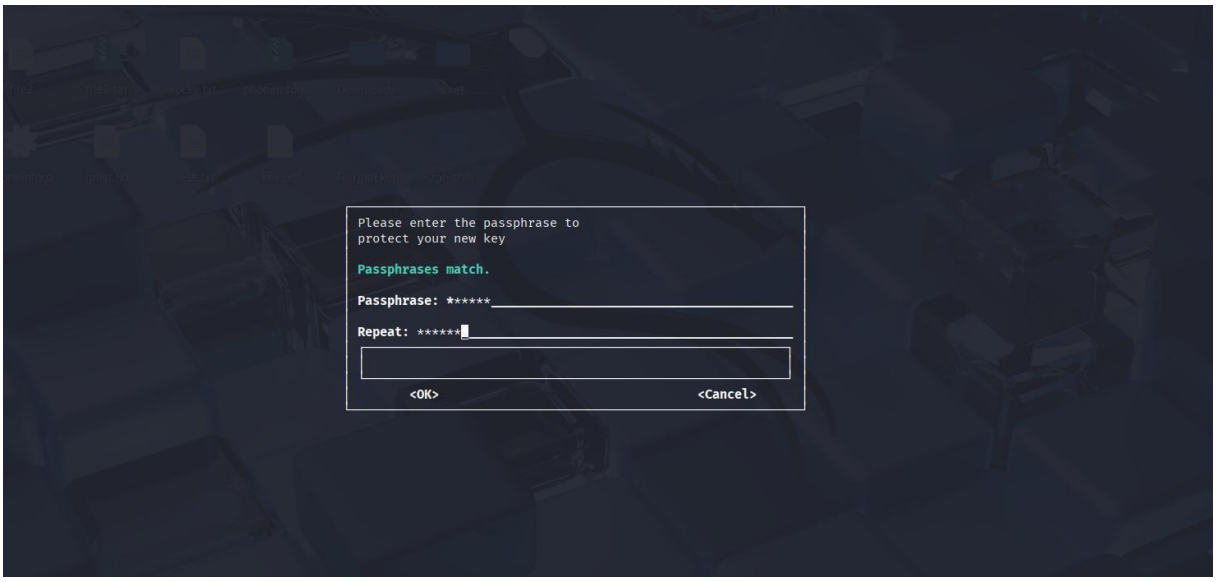
Step 1: Disk-Based Encryption (File / Partition Encryption)

- **Tool Used:** Veracrypt
- **How it was done:**
  - Created a secure virtual encrypted container (or encrypted volume) using VeraCrypt to protect sensitive files and folders.
  - Selected encryption algorithms (such as AES-256) and set a strong passphrase to secure the volume.
  - Mounted the encrypted container, added test files into it, and successfully unmounted (locked) it to verify data security.

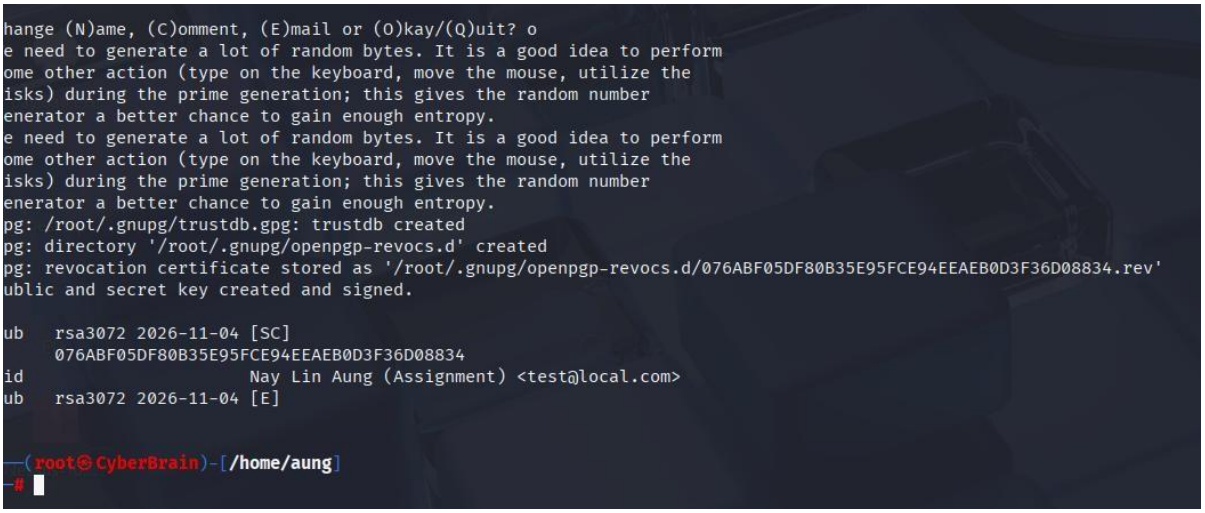
Step 2: Email Encryption

- **Tool Used:** GnuPG (GPG) / Thunderbird with Enigmail or PGP tools
- **How it was done:**
  - Generated a public/private key pair (RSA/ECC) for secure communication:





- Exported and shared the public key, while keeping the private key secure.



- Encrypted a sample text message/email file using the recipient's public key to ensure confidentiality: